

EXERCISE – Run Phase

This is a real documented case. Your target is **the Lapsus\$ group** — a threat actor collective whose members were publicly identified and arrested in 2022-2023. All attribution information is already public record — this is pure analytical reconstruction practice.

Your mission — using only public clearnet sources, reconstruct the attribution chain that led to the identification of at least two Lapsus\$ members. Document:

- What dark web / forum activity they engaged in
- What OPSEC failures led to their identification
- Which specific signals cracked each member
- Write a full analyst note with confidence ratings

Key sources to start with:

```
https://krebsonsecurity.com – search "Lapsus"  
https://www.bellingcat.com – search "Lapsus"  
https://www.justice.gov – search "Lapsus" press releases
```

Work independently.

Report back your full findings.

Overview of the Threat Actor

Lapsus\$ was a transnational group³ of threat actors based mainly in the United Kingdom (U.K.) and Brazil,⁴ with 8 to 10 known members as of April 2022.⁵ By some accounts, it formed out of members from two earlier cybercriminal groups known as Cyberteam⁶ and Recursion Team.

Consistent with the group's own statements,⁸ the Cyber Safety Review Board (CSRB, or the Board) received no evidence suggesting Lapsus\$ was affiliated with a nation-state or political entity.

In general, the threat intelligence community first observed and tracked Lapsus\$ as a named group between September and December 2021, which is when the group first posted on its public Telegram channel and attacked South American targets before pivoting to infiltrate many well-known international companies.

However, some researchers identified individuals using the Lapsus\$ moniker in forums to claim credit for alleged attacks as early as June 2021, indicating that the group or its members may have been active prior to the fall.

Additionally, security researchers observed suspected Lapsus\$ Telegram activity in March 2022 when a channel belonging to another extortion group reposted content from the official Lapsus\$ Telegram channel.

However, confirmation of Lapsus\$ involvement was not verified, and the Board saw no other apparent connection between the two groups.

Although Lapsus\$ as a named group does not appear to be active at the time of this report,¹⁴ the Board cannot rule out the possibility that Lapsus\$ members and affiliates have decided to limit their public profile, join other cybercrime groups, or rebrand.

As the Board cannot be definitive about the current existence of Lapsus\$, for simplicity, this report refers to Lapsus\$ in the past tense.

Lapsus\$ operated against the backdrop of a dynamic ecosystem of threat actors, each having specific tactics, preferring certain target sectors, malware, or methodology.

Within this threat ecosystem, Lapsus\$ emerged with different approaches to targeting, credential theft, and direct interaction with the public.

For example, Lapsus\$ used its private and public Telegram channels as a primary communication platform for operational coordination and engagement with its tens of thousands of followers, sharing efforts to recruit insiders at target companies, announcing its attacks, and taking polls on whom to target next.

Security researchers have faced challenges delineating Lapsus\$ activity from that of other threat actor groups. The relative commonality of their attack techniques and the connections between Lapsus\$ members and those in other threat actor groups have resulted in fragmented threat intelligence reporting and attribution.¹⁹ Some of these groups have provable ties to one another,²⁰ but the specifics of any individual relationships are difficult to determine.

Due to the fluid and overlapping nature of observed activity, the Board increased the aperture of study, and thusly, this report also includes some activities attributed by experts to other threat groups, including those named below:

- Yanluowang: Broadly identified as a ransomware affiliate group that is reported to have some connection with Lapsus\$ members.²¹ The group was active as of August 2021 and targeted organizations in the financial, manufacturing, information technology (IT), consultancy, and engineering sectors.
- Oktapus or Roasted Oktapus: A financially motivated group that is focused on accessing corporate services, obtaining crypto-related account information,²³ and stealing source code.
- Karakurt: A data extortion group²⁵ known for operating a dedicated leak site to auction stolen data.

- Nwgen Team: A financially motivated group that split off from Lapsus\$ mid-2022 and blended its original tradecraft with additional use of ransomware.
- **#NotLapsus** : Two other unidentified groups, **#NotLapsus1** and **#NotLapsus2** , which have successful alliances with Lapsus\$ members and other cybercriminals, such as Yanluowang.28

This report uses the term “threat actors” or “this class of threat actors” to refer to this superset of group activity the Board studied, referring specifically by name to any one group only where relevant.

#source : https://www.cisa.gov/sites/default/files/2023-08/CSRB_Lapsus%24_508c.pdf

TACTICS, TECHNIQUES, AND PROCEDURES (TTPs)

The threat actors described in this report leveraged a wide diversity of tactics, techniques, and procedures (TTPs), described by researchers as often mixing both non-complex methods and tools with advanced technical knowledge.

The threat actors initiated some attacks by employing common phishing methods or leveraging stolen credentials, which they purchased from initial access brokers (IABs). Other attacks demonstrated a deeper familiarity with a target’s business and engineering workflows.

Generally, the threat actors did not deploy custom tools, preferring well-known tools built by others or “living off the land” (LOTL).

The speed of the attacks and the use of different tools and techniques were notable and, in some cases, appeared automated.

The following sections outline some of the notable TTPs threat actors used as they worked across the aggregated set of targeted entities and are provided here to support the findings and recommendations below.

Where possible, descriptions of attack techniques are aligned to the MITRE ATT&CK® Framework taxonomy.

A quick look at some action they did

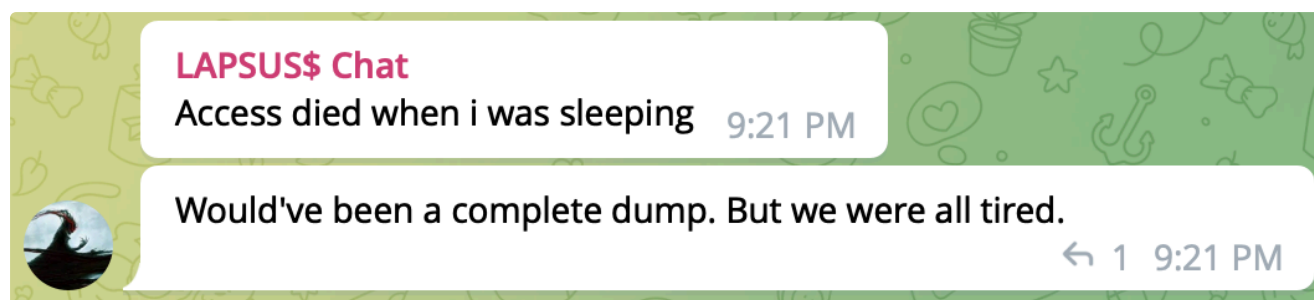
Report by Brian Krebs on March 23, 2022 says:

Microsoft and identity management platform **Okta** both this week disclosed breaches involving LAPSUS\$, a relatively new cybercrime group that specializes in stealing data from big companies and threatening to publish it unless a ransom demand is paid.

Here's a closer look at LAPSUS\$, and some of the low-tech but high-impact methods the group uses to gain access to targeted organizations.

First surfacing in December 2021 with an extortion demand on Brazil's Ministry of Health, LAPSUS\$ made headlines more recently for posting screenshots of internal tools tied to a number of major corporations, including **NVIDIA, Samsung, and Vodafone.**

On Tuesday, LAPSUS\$ announced via its Telegram channel it was releasing source code stolen from Microsoft. In [a blog post](#) published Mar. 22, Microsoft said it interrupted the LAPSUS\$ group's source code download before it could finish, and that it was able to do so because LAPSUS\$ publicly discussed their illicit access on their Telegram channel before the download could complete.



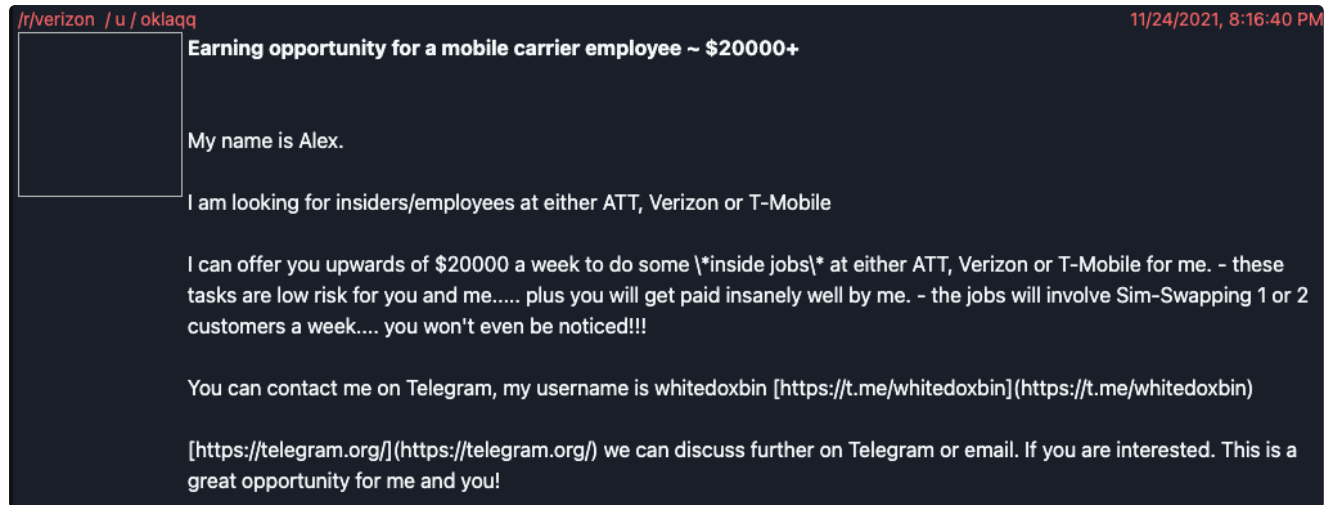
Context: One of the LAPSUS\$ group members admitted on their Telegram channel that the Microsoft source code download had been interrupted.

The Recruitment Campaign

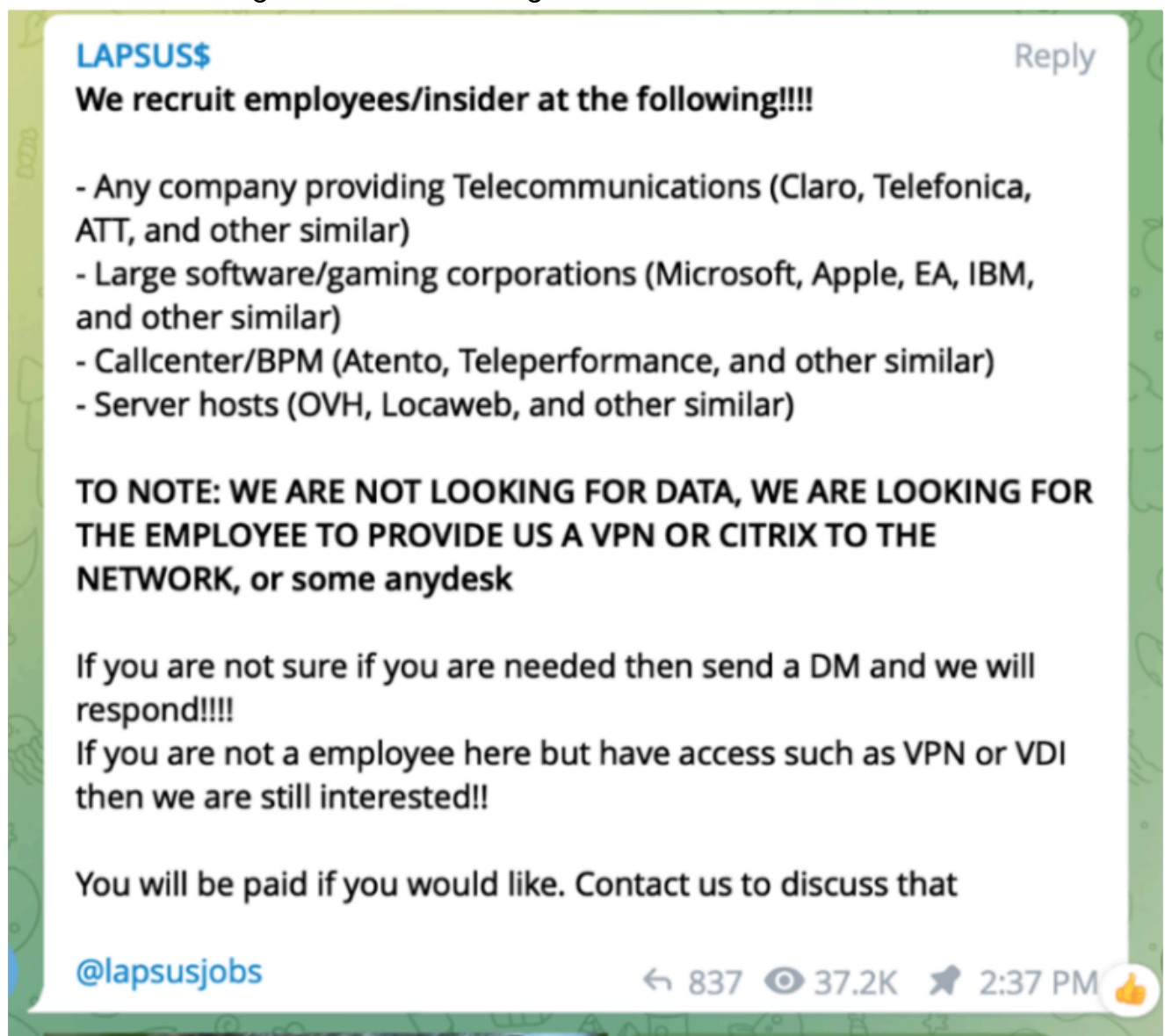
Confidence: high

Sources tell KrebsOnSecurity that LAPSUS\$ has been recruiting insiders via multiple social media platforms since at least November 2021. One of the core LAPSUS\$ members who used the nicknames "Oklaqq" and "WhiteDoxbin" [posted recruitment messages to Reddit last year](#), offering employees at AT&T, T-Mobile and Verizon up to \$20,000 a week to perform "inside jobs."

LAPSUS\$ leader Oklaqq a.k.a. "WhiteDoxbin" offering to pay \$20,000 a week to corrupt employees at major mobile providers:



LAPSUS\$ recruiting insiders via its Telegram channel:



Many of LAPSUS\$'s recruitment ads are written in both English and Portuguese. According to cyber intelligence firm [Flashpoint](#), the bulk of the group's victims (15 of them) have been in Latin America and Portugal.

Why is Nixon convinced LAPSUS\$ was behind the EA attack? The "WhiteDoxbin/Oklaqq" identity referenced in the first insider recruitment screenshot above appears to be the group's leader, and it has used multiple nicknames across many Telegram channels. However, Telegram lumps all aliases for an account into the same Telegram ID number.

Back in May 2021, WhiteDoxbin's Telegram ID was used to create an account on a Telegram-based service for launching distributed denial-of-service (DDoS) attacks, where they introduced themselves as "@breachbase." News of EA's hack last year was first posted to the cybercriminal underground by the user "Breachbase" on the English-language hacker community **RaidForums**, which was recently seized by the FBI.

WHO IS LAPSUS\$?

Confidence: Medium-high

Nixon said WhiteDoxbin — LAPSUS\$'s apparent ringleader — is the same individual who last year purchased the **Doxbin**, a long-running, text-based website where anyone can post the personal information of a target, or find personal data on hundreds of thousands who have already been "doxed."

Apparently, Doxbin's new owner failed to keep the site functioning smoothly, because top Doxbin members had no problems telling WhiteDoxbin how unhappy they were with his stewardship.

"He wasn't a good administrator, and couldn't keep the website running properly," Nixon said. "The Doxbin community was pretty upset, so they started targeting him and harassing him."

Nixon said that in January 2022, WhiteDoxbin reluctantly agreed to relinquish control over Doxbin, selling the forum back to its previous owner at a considerable loss. However, just before giving up the forum, WhiteDoxbin leaked the entire Doxbin data set (including private doxes that had remained unpublished on the site as drafts) to the public via Telegram.

The Doxbin community responded ferociously, posting on WhiteDoxbin perhaps the most thorough dox the community had ever produced, including videos supposedly shot at night outside his home in the United Kingdom.

According to the denizens of Doxbin, WhiteDoxbin started out in the business of buying and selling zero-day vulnerabilities, security flaws in popular software and hardware that even the makers of those products don't yet know about.

"[He] slowly began making money to further expand his exploit collection," reads his Doxbin entry. "After a few years his net worth accumulated to well over 300BTC (close to \$14 mil)."

WhiteDoxbin's Breachbase identity on RaidForums at one point in 2020 said they had a budget of \$100,000 in bitcoin with which to buy zero-day flaws in Github, Gitlab, Twitter, Snapchat, Cisco VPN, Pulse VPN and other remote access or collaboration tools.

"My budget is \$100000 in BTC," Breachbase told Raidforums in October 2020. "Person who directs me to someone will get \$10000 BTC. Reply to thread if you know anyone or anywhere selling this stuff. NOTE: The 0day must have high/critical impact."

KrebsOnSecurity is not publishing WhiteDoxbin's alleged real name because he is a minor (currently aged 17), and because this person has not officially been accused of a crime. Also, the Doxbin entry for this individual includes personal information on his family members.

Nixon said that prior to launching LAPSUS\$, WhiteDoxbin was a founding member of a cybercriminal group calling itself the "[Recursion Team](#)." According to the group's now-defunct website, they mostly specialized in SIM swapping targets of interest and participating in "[swatting](#)" attacks, wherein fake bomb threats, hostage situations and other violent scenarios are phoned in to police as part of a scheme to trick them into visiting potentially deadly force on a target's address.

"The team is made up of Cyber-enthusiasts who major in skills including security penetration, software development, and botting," reads the now-defunct Recursion Team website. "We plan to have a bright future, and we hope you do too!"

Update, March 24, 11:11 a.m. ET 2022: The BBC is quoting City of London Police as saying [seven people between the ages of 16 and 21 have been arrested](#) in connection with an investigation into a hacking group. All have been released under investigation.

What now?

Now that we have acquired enough basic intel on the Lapsus\$ group i can start accomplish my goal and document:

- What dark web / forum activity they engaged in
- What OPSEC failures led to their identification
- Which specific signals cracked each member

What dark web / forum activity they engaged in?

Confidence: High

Lapsus\$ primarily operated through a **private Telegram channel** rather than traditional dark web leak sites, using it to announce attacks, share stolen data, and communicate with the public. However, the group also utilized several other platforms for coordination and extortion:

- **Telegram:** The main hub for their operations, boasting tens of thousands of subscribers, where they posted claims of responsibility and recruited malicious insiders.
- **Doxbin:** A controversial deep web paste site where the group shared hacked internal documents and from which a potential leader's identity was later leaked.
- **RaidForums:** An underground hacking forum where members posted about compromises (such as those related to FIFA games) and shared PGP keys.
- **XSS and Exploit Forums:** Russian hacking forums where members, such as the alias "4c3," posted about stolen data.
- **BreachForums:** While primarily associated with the later "Scattered Lapsus\$ Hunters" alliance (which included Lapsus\$ members), this site served as a data leak platform for extortion campaigns involving Salesforce and other targets.

The main Opsec Failure that led to exposure

Confidence: High

The **Lapsus\$** group, despite successfully breaching major corporations like **Microsoft**, **NVIDIA**, and **Okta**, was characterized by significant **operational security (OPSEC) failures** that exposed their identities and tactics.

Key failures included:

- **Identity Exposure:** A prominent member known as "**White**" (identified as a 16-year-old in the UK) leaked the **Doxbin** user database in plaintext during an internal dispute, revealing his own personal information and password hashes.
- **Poor Anonymization:** The group often **exposed their infrastructure** and internal systems while boasting about breaches, such as leaving **Azure DevOps** screenshots with identifiable metadata or using non-anonymized communication channels.
- **Social Engineering Reliance:** Instead of sophisticated technical exploits, Lapsus\$ heavily relied on **bribing or tricking employees** (social engineering) and **insider threats**, often using **SMS-based multi-factor authentication (MFA)** which they easily bypassed through SIM swapping or social engineering help desks.
- **Premature Disclosure:** They frequently **publicized their intrusions** on Telegram and forums before securing the data or confirming the extent of the breach, allowing defenders to interrupt operations (e.g., Microsoft cutting off access mid-exfiltration).
- **Lack of Discipline:** The group was described as **immature and disorganized**, with members engaging in public drama and infighting, which attracted law enforcement attention and led to rapid apprehensions.

These failures contrasted with their technical success, demonstrating that **human error and poor operational hygiene** can compromise even high-profile threat actors.

Signals Cracked

Confidence: low-medium

there is **no information** regarding specific "signals" that were cracked to identify or apprehend each individual member of the Lapsus\$ group.

The search results indicate that the group's members were identified and arrested through the following methods, rather than the cracking of specific technical signals:

- **Operational Security Failures:** Members had **doxxed** (publicly released personal information about) each other out of annoyance. One prominent member, **Arion Kurtaj** (pseudonym "White"), was identified because his identity had allegedly been disclosed by a former associate.
- **Public Telegram Activity:** The group operated a public Telegram channel with nearly 50,000 subscribers, where they boasted about attacks, recruited insiders, and posted internal screenshots, which allowed cybersecurity researchers and law enforcement to track their activities and associate specific usernames with real-world identities.
- **Law Enforcement Investigation:** In March 2022, the **City of London Police** arrested seven suspected members aged 16 to 21 following an investigation. The FBI had made an appeal for information on March 21, 2022, prior to the arrests.
- **Cybersecurity Firm Research:** Groups such as **Unit 221B** and **Flashpoint** tracked individual members and their associated nicknames (e.g., "Oklaqq," "WhiteDoxbin") through their recruitment ads on platforms like Reddit and Telegram, linking them to the group before the police arrests.

The context mentions that Microsoft interrupted a data download because Lapsus\$ publicly discussed the operation on Telegram, but this refers to **stopping the attack**, not identifying individual members via cracked signals.